Vulnerability and Patch Management Procedure

Document ID	SEC-007
Department	IT and Information Security
Document type	Procedure
Owner	Security Engineering Manager
Version	3.2
Status	APPROVED
Effective / last reviewed	2026-03-21
Audience	All employees and contractors
Related documents	SEC-004, ENG-007, ENG-015, SEC-015

Summary. Procedure for finding, rating, fixing and verifying vulnerabilities at Northstar. Sets remediation deadlines by CVSS severity, actively exploited vulnerability handling, weekly scans, annual penetration test, the monthly server patch window, exceptions and reporting.

SYNTHETIC DOCUMENT - Northstar Systems is a fictional company. This document exists for development, testing and demonstration only and is not real legal, employment, security or compliance advice.

1. Purpose and Scope

This procedure explains how Northstar Systems finds vulnerabilities, rates them, assigns them to owners, fixes them within fixed deadlines and proves that the fix worked. It implements the vulnerability management control in SEC-001 (Information Security Policy) and works with SEC-004 (Device Security and Endpoint Policy) for laptop patching, ENG-007 and ENG-015 for engineering change and dependency practice, and SEC-015 for monitoring.

It applies to every system Northstar owns or operates: laptops and phones, corporate servers, network equipment, cloud infrastructure in the Mumbai primary and Hyderabad disaster recovery regions, the build and delivery platform NorthShip, internal applications, and the Northstar Nexus Platform, Nexus Connect and Nexus Insight services. It also applies to third-party and open-source components inside Northstar products. Legal and regulatory references in this document are illustrative and must be verified by Legal before external use.

2. Definitions

- **Vulnerability**: a weakness in software, configuration or process that could be exploited to harm confidentiality, integrity or availability.
- **CVSS**: the Common Vulnerability Scoring System, producing a base score from 0.0 to 10.0.
- **Triage**: the point at which Security Engineering confirms a finding, validates the score and assigns an owner. The remediation clock runs from detection or triage, as set in section 5.
- **Remediation**: fixing the weakness by patching, upgrading, reconfiguring or removing the affected component.
- **Mitigation**: reducing the risk without a full fix, for example blocking a port, adding a firewall rule, disabling a feature or applying a web application firewall rule.
- **Actively exploited**: a vulnerability for which credible information shows attacks happening in the wild, for example a listing in a public known-exploited catalogue or a trusted threat intelligence alert.

- **Asset owner**: the person accountable for the system that has the vulnerability.
- **Patch window**: a scheduled period when servers may be patched and restarted.
- **SBOM**: a software bill of materials listing the components in a release.
- **Risk acceptance**: a documented decision by the CISO delegate to tolerate a vulnerability for a limited time.

3. Roles and Responsibilities

Role	Responsibility
Security Engineering Manager	Owns this procedure, runs scanners, triages findings, reports metrics
Asset owners	Fix or mitigate findings on their systems within the deadlines
Head of IT Operations	Patches laptops, servers and network equipment, runs the monthly patch window
Engineering Directors and team leads	Fix application and dependency vulnerabilities, prioritise them in sprints
CISO delegate (Incident Response Lead)	Approves risk acceptances and declares an incident for actively exploited issues
Security Champions	Help engineering teams interpret findings and review security-sensitive fixes
CISO	Reviews overdue findings at the quarterly security review

4. Discovery

Northstar uses several sources of vulnerability information and every source feeds one backlog in NorthDesk.

1 **Weekly vulnerability scans** of servers, cloud workloads, containers and network devices, run by Security Engineering. Authenticated scans are used where possible.
2 **Code and dependency scanning** in NorthShip on every commit and build. A build with a new critical vulnerability in a dependency is blocked, in line with the engineering rule that no new dependency may be added with an unpatched critical vulnerability.
3 **Annual penetration test** by an external firm, covering the Nexus Platform, internal network and cloud configuration. Findings are loaded to the NorthDesk backlog within 5 business days of report receipt.
4 **Vendor and public advisories** from software suppliers, the cloud provider and recognised security bulletins, monitored daily by Security Engineering.
5 **Endpoint reports** from NorthGuard on missing patches.
6 **Reports from people**: customers, researchers or employees who report a weakness to the Security Desk (extension 5555 or security@northstar-systems.example).
7 **SBOM review** for each release of the Nexus products.

5. Severity Ratings and Remediation Deadlines

5.1 Rating

Security Engineering starts from the CVSS base score and may adjust the priority using context: exposure to the internet, presence of Restricted data on the system, whether a working exploit exists, and compensating controls. The context can raise a finding's priority but never lowers the deadline defined by the base score without a risk acceptance.

5.2 Deadlines

Severity	CVSS score	Remediation deadline from detection or triage
Critical	9.0 to 10.0	72 hours
High	7.0 to 8.9	14 days
Medium	4.0 to 6.9	30 days
Low	Below 4.0	90 days
Actively exploited (any severity)	Any	Mitigation within 24 hours

The clock starts at detection or triage, whichever the procedure records first, and is stopped only when the fix is verified. Deadlines are calendar-based and are not paused by weekends or holidays for Critical and actively exploited findings. If a weekend falls inside a deadline for High, Medium or Low findings, the owner must still plan to meet it.

5.3 Actively exploited vulnerabilities

1 The Security Engineering Manager informs the CISO delegate immediately.
2 A mitigation must be in place within 24 hours, even if the full patch is not yet available. Typical mitigations are blocking an exposed port, disabling a feature, adding a WAF rule or isolating the system.
3 The CISO delegate may declare a security incident under SEC-001 if there is evidence of exploitation at Northstar. The Incident Response Lead then leads the response through detect, triage, contain, eradicate, recover and review.
4 The full remediation follows the normal deadline for its CVSS band, or is faster where possible.

Example: A Critical vulnerability (CVSS 9.8) is announced in a library used by the Nexus Connect gateway and is listed as actively exploited. Security Engineering confirms it at 10:00 on a Wednesday. A WAF rule is deployed by the next morning, which meets the 24-hour mitigation limit. The patched library is built and rolled out through NorthShip using the emergency change route, and the fix is verified inside the 72-hour Critical deadline.

Example: A scan on 5 May finds a Medium vulnerability (CVSS 5.4) on an internal reporting server. The deadline is 30 days, so the fix is due on 4 June. The owner schedules it for the next patch window.

6. Procedure Step by Step

1 **Detect.** A scan, advisory or report identifies a possible vulnerability.
2 **Triage (within 1 business day for Critical and High, 3 business days for others).** Security Engineering confirms that the finding is real, removes duplicates, validates the CVSS score, finds the asset owner and records the finding in NorthDesk with the deadline from section 5.
3 **Assign.** The ticket is assigned to the asset owner. Critical findings also notify the Engineering Director or Head of IT Operations by direct message.
4 **Plan the fix.** The owner chooses patch, upgrade, configuration change or mitigation. Production changes need a NorthDesk change ticket and rollback plan, and follow the engineering change rules (see ENG-007). A Critical or actively exploited fix may use the Emergency change route, approved by the Engineering Director on call, with retrospective review in 1 business day.

5 **Test and deploy.** Fixes are tested in a lower environment when time allows, and deployed in the next suitable window, or immediately when the deadline demands it.
6 **Verify.** Security Engineering rescans or retests to confirm the fix. A finding is closed only after verification, not when the change is deployed.
7 **Close and record.** The ticket records evidence: scan output, version numbers and the closure date.
8 **Review.** Repeated findings of the same kind are analysed so that the root cause (for example an old base image) is fixed.

6.1 Worked scenario: monthly patch cycle

On the second Saturday of a month the Head of IT Operations runs the patch window from 22:00 to 02:00 IST. A weekly scan on the preceding Monday listed 3 High findings on 40 application servers, all with a 14-day deadline. The plan, published 7 days earlier, patches the Tier-3 servers first, then Tier-2, then Tier-1 in rolling batches. At 23:30 one Tier-1 batch fails a health check, so the operator rolls it back within 15 minutes and logs the reason in the change ticket. The remaining batches finish at 01:10, and on Monday Security Engineering rescans and closes 118 of 120 findings. The 2 remaining findings are on the failed batch. Because their 14-day deadline falls before the next window, the owner raises an emergency patch under the rules in section 7.5.

7. Patch Management

7.1 Servers and infrastructure

Servers are patched in the monthly patch window, held on the second Saturday of each month from 22:00 to 02:00 IST. The Head of IT Operations publishes the plan 7 days before and tracks completion. Patches for Critical and actively exploited vulnerabilities are not held for the window; they use an emergency or out-of-band patching route. Patching of Tier-1 services must be sequenced so that the service stays available, using rolling updates, and each production change follows the deployment rules in ENG-007. The window does not replace the need for a NorthDesk change ticket.

7.2 Laptops and phones

Operating system patches must be installed on company devices within 14 days of release, as required by SEC-004. NorthGuard pushes updates, and users may defer them only up to 3 times. A device that stays unpatched beyond the period loses access to corporate systems until it is fixed. Critical patches for endpoints follow the 72-hour Critical deadline and may be forced.

7.3 Applications and dependencies

Engineering teams keep application dependencies current. Teams should review dependency updates at least every sprint. A critical vulnerability in a dependency must be fixed within 72 hours, and the fixed release is built through NorthShip with an updated SBOM. Open source components must follow the allowed licence list in ENG-015. Containers are rebuilt from patched base images at least monthly.

7.4 Cloud and network configuration

Misconfigurations found by cloud posture scanning are rated with the same CVSS-style approach and use the same deadlines. Firewall rules are reviewed every quarter and follow default-deny. Public exposure of a service that is not meant to be public is treated as High at minimum.

7.5 Emergency patching during freezes and Friday restrictions

Production deployment normally happens Tuesday to Thursday between 10:00 and 16:00 IST, and quarter-end freezes apply to the last 3 business days of each quarter. A vulnerability fix that would breach its deadline if held until the next permitted window may use the Emergency change route. The Engineering Director on call approves it, a NorthDesk change ticket and rollback plan are still mandatory, and the retrospective happens within 1 business day. Medium and Low fixes wait for the normal windows because their deadlines allow it. The rollout follows the canary approach of 10 percent, 50 percent and then 100 percent, and an automatic rollback applies if the error rate is above 2 percent for 5 consecutive minutes.

7.6 Third-party and customer-hosted components

Where Northstar relies on a supplier's product, the supplier's patch is applied within the same deadlines from the date the patch is available. If the supplier is slow, the asset owner records the delay and requests a risk acceptance. Customers who run self-managed Nexus versions are told which versions carry fixes; a customer on 4.3, whose support has ended, must upgrade through 5.0 or 5.1 (a direct 4.3 to 5.1 upgrade is supported) to receive security fixes.

7.7 Verification and false positives

A scanner finding that the owner believes to be a false positive must be challenged in the ticket with evidence, such as the installed version or a configuration screenshot. Security Engineering decides within 3 business days. Confirmed false positives are tagged so that the scanner does not raise them again, and the tag is reviewed every 6 months. The deadline clock continues to run while the challenge is being reviewed.

8. Exceptions and Risk Acceptance

If a vulnerability cannot be fixed within its deadline, the asset owner must raise a risk acceptance request in NorthDesk before the deadline expires.

1 The request states the finding, the reason the fix is not possible, the compensating controls, a remediation plan and the proposed expiry.
2 The Security Engineering Manager reviews and recommends.
3 The CISO delegate approves or rejects the risk acceptance.
4 A risk acceptance lasts at most 90 days. Renewal needs fresh justification and a progress report.
5 Accepted risks are listed at the quarterly security review.

Example: A vendor has not yet released a patch for a High vulnerability in a licensed monitoring appliance. The asset owner requests a risk acceptance on day 10 of the 14-day deadline, restricts network access to the appliance management port, and adds a weekly check for the vendor patch. The CISO delegate approves for 60 days. If the patch arrives sooner, the owner must apply it within 14 days of its release.

A finding that passes its deadline without a fix or an approved acceptance is overdue. The overdue finding is escalated to the Director, then to the CTO or the Head of IT Operations, and reported to the CISO.

9. Responsible Disclosure and Customer Communication

External researchers who report a weakness are acknowledged within 2 business days and kept informed. Northstar does not take action against good-faith research that follows the disclosure rules. When a vulnerability in a Nexus product affects customers, Customer Success and Engineering decide on communication. Customers are notified through approved channels, with no promise of dates unless Engineering confirms. Security patches for supported versions (4.2 LTS and 5.0 LTS, and 5.1 until its support ends) are released first for the supported versions in line with the support policy.

10. Metrics and Reporting

Security Engineering reports monthly and at the quarterly security review: the number of open findings by severity, the percentage closed within deadline (target 95 percent for Critical and High), mean time to remediate, overdue items, accepted risks, scan coverage and the status of the annual penetration test findings. A high audit finding must be remediated within 60 days. Results feed the risk register maintained under SEC-001.

11. Frequently Asked Questions

- How fast must a Critical vulnerability be fixed? Within 72 hours of detection or triage.
- What about High? 14 days. Medium 30 days. Low 90 days.
- What if a vulnerability is already being exploited? A mitigation within 24 hours is required.
- When are servers patched? In the monthly window on the second Saturday, 22:00 to 02:00 IST.
- How often do we scan? Weekly, with a penetration test once a year by an external firm.
- Who can approve a delay? The CISO delegate, with an expiry of at most 90 days.

12. Related Documents

See SEC-004 for device patching, ENG-007 for change and deployment rules, ENG-015 for dependency and open source rules, and SEC-015 for monitoring. The overall policy is SEC-001.

13. Revision History

Version	Date	Change
3.0	2025-06-17	Added actively exploited rule and CVSS bands
3.1	2025-11-03	Clarified risk acceptance maximum and verification step
3.2	2026-03-21	Updated patch window, metrics and dependency rules